

Controls and compliance checklist

Botium Toys internal security audit

Controls assessment checklist

Does Botium Toys currently have this control in place?

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

Recommendations (optional)

After going through the risk assessment report, I noticed that Botium Toys does a decent job with their physical controls but is missing a lot of the controls that actually protect their data. Here is what I think should be added, starting with what seems most urgent:

- Least privilege and separation of duties. Right now every employee can get to internally stored data, including credit card info and customer PII/SPII. Not everyone needs that access, and limiting it would lower the risk a lot.
- Encryption. Credit card data is being accepted, processed, transmitted, and stored without encryption, which is a PCI DSS violation and could lead to fines.
- Disaster recovery plans and backups. There are none of either, so if something went wrong there would be no way to recover the data.
- Intrusion detection system (IDS). They have a firewall and antivirus, but nothing that would detect suspicious activity once it is already inside the network.
- Better password policy and a password management system. The current policy does not meet the minimum complexity requirements, and without a central system there is no way to enforce it. It would also cut down on all the password reset tickets IT deals with.
- Asset inventory and classification. The IT department does not know which assets are at risk, which is why the impact rating is only medium. This is the Identify function of the NIST CSF and it also ties into GDPR.
- A set schedule for legacy system monitoring. They do monitor these systems, but there is no regular schedule and the intervention methods are unclear.

Things they are already doing well and should keep doing: the firewall, antivirus software, the 72-hour breach notification plan for E.U. customers, their privacy policies, and the locks, CCTV, and fire detection at the store location.

Note on password policies: I marked this "yes" because a policy does exist, but it is not strong enough and still needs to be updated.